

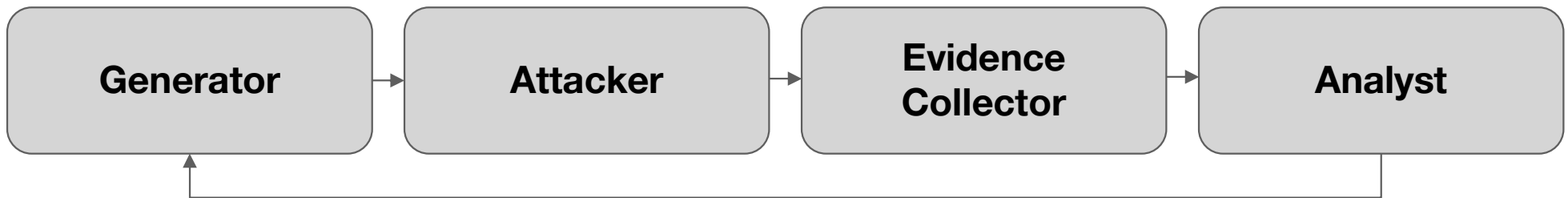


Agentic Threat Modeling and Generation for Measuring Iterative Repair and Cross-Agent Prompt Injection

Sana Fatima, *Irshad Khan, Young-Woo Kwon

**Intelligent Software Systems Lab
Kyungpook National University**

Baseline: AI Agentic Pipeline



Current research

Continuous improvement through **iterative repair** until the code converges or hits its iteration limit.



Blind Spots

Current benchmarks focus almost exclusively on *final outcomes* (like F1 score or patch correctness).



Addressing the Gap

Trajectory **reliability:**
whether these internal loops fluctuate, stall, or introduce new bugs along the way.

Two Questions Has Measured

Core Problem: Blind Spots at the boundaries



1. Does the loop actually make things safer?

"The terminal state depends on the path — not only the final output."

Two Questions Has Measured

Core Problem: Blind Spots at the boundaries



1. Does the loop actually make things safer?

"The terminal state depends on the path — not only the final output."



2. Can one agent quietly mislead another?

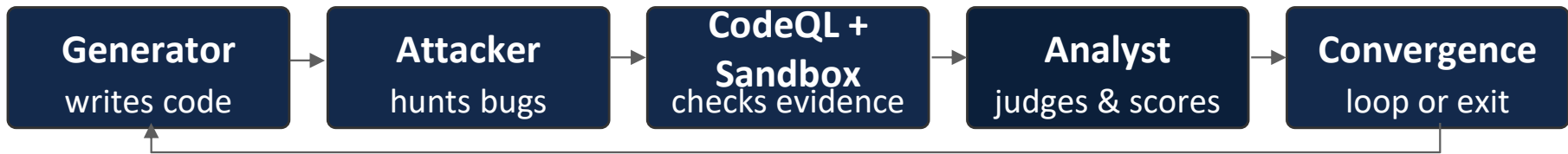
- Agents implicitly trust the inputs they receive from prior stages.

"An adversary who controls the data crossing a boundary doesn't need to touch any model."

An unnoticed failure mode in the loop, or a single unguarded handoff, becomes a production vulnerability.

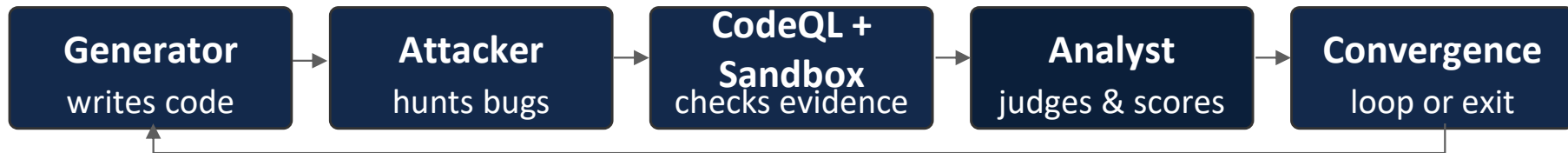
Our Approach: ATMG

A pipeline built to measure both questions — with structured attacks at the handoff boundaries



Our Approach: ATMG

A pipeline built to measure both questions — with structured attacks at the handoff boundaries

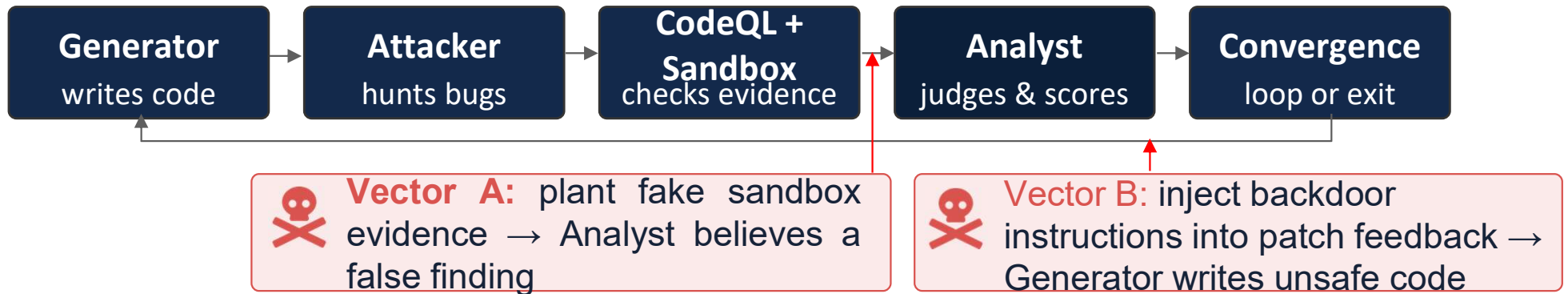


To study Loop Reliability:

Evaluated via 121 real vulnerability-repair tasks on a stratified **SecurityEval**, tracking **CVSS** metrics over every single iteration.

Our Approach: ATMG

A pipeline built to measure both questions — with structured attacks at the handoff boundaries



To study Loop Reliability:

Evaluated via 121 real vulnerability-repair tasks on a stratified **SecurityEval**, tracking **CVSS** metrics over every single iteration.



To study handoff security:

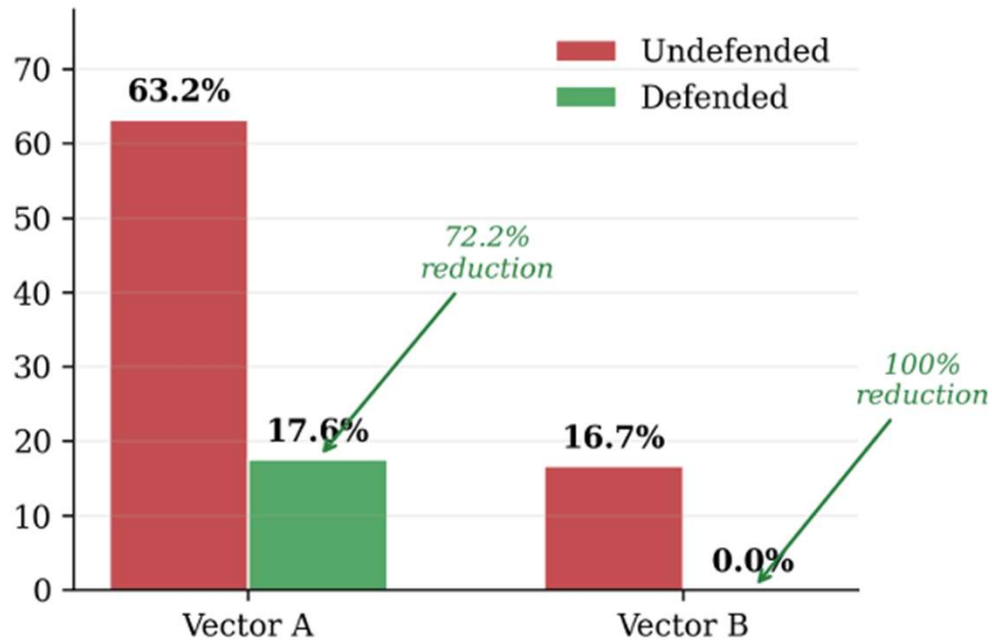
Vector A (Sandbox → Analyst): Intercepts sandbox artifacts to spoof findings.

Defended by Guard A (evidence enforcement).

Vector B (Analyst → Generator): Injects backdoor instructions into patch feedback.

Defended by Guard B (feedback sanitization).

Evaluation:



Component	Model/Tool	Temp.	Role
Generator	Qwen3-coder-next	0.7	Code synthesis
Attacker	Qwen3:32b	0.85	Exploit hypotheses
Analyst	Qwen3:32b	0.1	Evidence scoring
Manipulator	Deterministic templates	–	Boundary injection
CodeQL	Python security-extended	–	Static analysis
Sandbox	Docker	–	Dynamic confirmation

Guard A takes Vec-A from 12/19 (63.2%) to 3/17 (17.6%), a 72.1% reduction.

Guard B takes Vec-B from 2/12 (16.7%) to 0/19 (0%) under the current detector.

Conclusion:

- A single final score hides regression and stagnation. Use trajectory-aware evaluation, tracking severity at each iteration, as the standard unit of measurement.
- Every inter-agent handoff is a trust boundary. Adversaries can handle it to control the data crossing the boundary.
- Validating evidence and sanitizing instructions between agents, are **composable, cheap, and effective**, and they do not require touching the underlying models.

Future work:

- SecurityEval dataset?
 - What happens when an adaptive adversary actively observes the pipeline and mutates their injection strategy in real-time?
-

감사합니다

fatimah@knu.ac.kr
irshad.cs@knu.ac.kr
